信息安全测评与风险评估

5.1 安全管理文档核查

授课教师：张玉



目录

CONTENTS

01 案例导入——“技术满分，管理零分”的教训

02 学习目标

03 安全管理测评——在等保标准中的位置

04 安全管理制度测评的核心指标

案例导入——“技术满分，管理零分”的教训



引入问题：如果技术防护做得好，但管理文档落灰，它安全吗？

案例背景：某企业通过等保三级技术测评（架构合理/防火墙严格/漏洞无高危），但半年后发生严重数据泄露。

调查发现管理漏洞：

- 无明确的安全事件响应流程
- 离职员工账号有效且权限未回收
- 外包人员未签保密协议随意拷数据
- 安全审计日志混乱无法追溯
- 管理制度文档3年未更新

问题讨论：

- **技术测评通过，为何还会出事？**
- **“三分技术，七分管理”何意？**
- **安全管理文档为何如此重要？**

学习目标

通过本课学习，你将能够：

- **理解**安全管理测评在等保2.0中的核心地位与五大维度
- **掌握**安全管理文档核查的方法与流程
- **能够**对照GB/T 22239安全管理要求，对制度文档进行逐项核查
- **能够**识别安全管理方面的常见问题并提出初步改进建议
- **具备**安全管理体系分析与合规性判断能力

安全管理测评——在等保标准中的位置

GB/T 22239-2019 管理要求 → 五大维度之一：安全管理制度

等保2.0管理体系框架：

序号	管理维度	核心内容	本课重点
1	**安全管理制度**	安全策略、管理制度、制定和发布、评审和修订	☆ ☆ ☆
2	安全管理机构	岗位设置、人员配备、授权审批、沟通合作等	☆ ☆
3	安全管理人员	人员录用、离岗、培训、外部人员访问管理	☆ ☆
4	安全建设管理	定级备案、方案设计、产品采购、软件开发等	☆ ☆
5	安全运维管理	环境管理、资产管理、介质管理、设备维护等	☆ ☆

本课重点： 安全管理制度的四个控制点（安全策略、管理制度、制定和发布、评审和修订）

安全管理制度测评的核心指标

安全管理制度的四个控制点（三级要求）

控制点	核心要求	检查方式
安全策略	应制定网络安全工作的总体方针和安全策略，阐明总体目标、范围、原则和安全框架	查阅《网络安全总体方针》文档
管理制度	对各类管理内容建立安全管理制度；对日常管理操作建立操作规程；形成由安全策略、管理制度、操作规程、记录表单构成的完整体系	查阅管理制度汇编
制定和发布	指定或授权专门部门/人员负责制定；通过正式、有效方式发布，版本控制	查看发布记录、版本号
评审和修订	定期对制度的合理性和适用性进行论证和审定，对存在不足的进行修订	查看评审记录、修订记录

一句话总结： 安全管理制度测评就是检查“有没有制度→制度全不全→制度发布没→制度更新没”。

安全管理制度体系建设

素材4：安全管理
文档——应有制度

安全管理体系四层文档结构



层级	文档类型	内容说明	示例
第一层	总体方针/安全策略	最高层指导文件，阐明安全工作的总体目标、范围、原则、安全框架	《网络安全总体方针》《信息安全总体策略》
第二层	管理制度	针对各类安全管理活动建立的具体制度	《网络安全管理制度》《数据安全管理制度》《人员安全管理制度》
第三层	操作规程	针对日常管理操作的具体步骤和规范	《系统运维操作规程》《账号管理操作规程》《备份恢复操作规程》
第四层	记录表单	执行过程的记录证据	审批表、巡检记录表、备份记录表、事件报告单

关键点

这四层文档之间应具有连贯性、完备性——方针指导制度，制度细化成规程，规程产生记录。

安全管理制度——逐项核查要点（一）

第一项：安全策略（总体方针）

检查点	内容要求	常见问题
是否有总体方针文件	应有《网络安全总体方针》或《信息安全总体策略》	完全没有此类文件

第二项：管理制度

检查点	内容要求	常见问题
管理制度是否全面	应覆盖安全管理各领域（网络、系统、数据、人员、运维等）	只覆盖部分领域

安全管理制度——逐项核查要点（二）

检查点	内容要求	常见问题
是否有专门负责部门	应有明确的责任部门/人员	无人负责
是否正式发布	应有红头文件或正式通知	只有草稿
是否版本控制	应有版本号、修订记录	无版本号

检查点	内容要求	常见问题
是否定期评审	应定期对制度进行评审（如每年一次）	从未评审
是否有修订记录	制度修订应有记录	修订无记录

安全管理文档核查——五步法（15分钟）

安全管理测评文档核查流程：

01

获取文档

根据检查文档列表，获取制度、记录、规程等各类文档，填写文档交接单

确保文档完整、不遗漏

02

审阅文档

审阅各类文档，在现场测评作业指导书中进行结果记录

对照标准逐项检查

03

记录发现

对发现的问题详细描述，标注标准依据

问题描述要具体

04

补充访谈

针对不确定项访谈相关人员，获得额外证据

不能凭猜测下结论

05

确认签字

整理测评记录，确认签字；归还所有文档，在交接单中签字

确保文档不丢失

核查与访谈的关系

通过访谈获得信息，通过核查验证信息——两者相辅相成，缺一不可。

场景	核查方法	访谈方法
检查是否有制度文档	查阅文档清单	询问负责部门
检查制度是否执行	查阅执行记录	询问相关人员
检查制度是否更新	查看版本号、修订记录	询问评审周期
检查人员是否知晓	无法直接核查	访谈相关人员

教师演示——文档核查操作

素材5：教师演示用——安全管理文档

演示场景

教师提供一套模拟的“XX公司安全管理制度文档包”，包含：

- 《网络安全总体方针》（有审批、有日期）✓
- 《网络安全管理制度》（内容完整）✓
- 《人员安全管理制度》（内容不完整）⚠
- 《系统运维操作规程》（有但过于简单）⚠
- 《应急预案》（无审批、无日期）✗
- 无评审记录 ✗

教师演示步骤

01 对照标准要求，列出应有制度清单

02 逐一检查文档是否存在

03 对存在的文档检查内容是否完整

04 检查是否有发布审批和版本控制

05 检查是否有评审和修订记录

06 填写《安全管理文档核查表》

实践任务1——安全管理文档核查



素材2：实践任务
——《安全管理文档

要素	内容
任务名称	安全管理文档合规性核查
任务场景	教师提供一套模拟的XX公司安全管理制度文档包（包含完整文档和缺陷文档）（素材1）
任务内容	对照GB/T22239安全管理要求（素材4），逐一核查文档包是否覆盖所有应有制度逐份审阅文档内容，检查是否完整检查审批、版本、评审等管理要素填写《安全管理文档核查表》（素材2）
时间安排	约20分钟

实践任务1——《安全管理文档核查表》填写说明

字段	填写要求	示例
应有制度文件	列明GB/T 22239要求的制度名称	《网络安全总体方针》
是否具备	是/否	是
是否有审批	是/否（审批人、日期）	是（张XX，2026-01-15）
是否版本控制	是/否（版本号、修订记录）	是（V2.0，有修订记录）
内容是否完善	是/否/部分	部分（缺应急预案章节）
问题/备注	具体问题描述	应急预案内容不完整，缺具体流程

安全管理文档常见问题汇总

问题类型	具体表现	风险影响
制度缺失	缺少必要的安全管理制度文档	安全管理无章可循
内容空洞	制度内容套话连篇，缺乏可操作性	制度无法有效执行
版本陈旧	制度多年未更新，与现状不符	制度形同虚设
未审批发布	制度无审批签字、无发布日期	制度不具备权威性
执行无记录	只有制度文本，没有执行记录	

思政融入——安全管理的“制度意识”

制度是安全的基础	“三分技术，七分管理”——再强的技术，没有制度保障也难以持续。安全管理文档不是“纸上谈兵”，而是安全工作的“基本法”。
制度是责任的体现	一份完善的制度文档，体现的是组织对安全的重视。制度的缺失，往往意味着责任的缺失。
制度是合规的底线	等保测评中，管理要求的权重占比与技术同等重要。没有制度的支撑，技术做得再好也难以通过测评。

安全管理文档核查，不仅是在检查文件，更是在审视一个组织的安全文化。

实践任务2——安全管理综合测评（15分钟）

要素	内容
任务名称	安全管理综合测评与整改建议
任务场景	实践任务1的成果
任务内容	① 汇总发现问题 ② 分类整理问题（制度/内容/执行缺失等） ③ 提出整改建议 ④ 形成《汇总表》
成果要求	分类清晰、整改具体可行

实践任务2——《安全管理测评汇总表》（素材3）

序号	测评维度	问题描述	不符合项标准依据	整改建议	优先级
1	安全策略				
2	管理制度				
3	制定和发布				
4	评审和修订				

填写说明：

- **测评维度：**安全策略/管理制度/制定和发布/评审和修
- **问题描述：**具体、准确
- **标准依据：**标注GB/T 22239具体条款
- **整改建议：**具体、可操作
- **优先级：**高/中/低

知识点回顾（5分钟）

本课核心知识

- **一 安全管理测评概述**
  在等保2.0中的位置：管理要求-安全管理制度四个控制点：安全策略、管理制度、制定和发布、评审和修订
- **二 安全管理体系四层结构**
  总体方针 → 管理制度 → 操作规程 → 记录表单四层应具有连贯性、完备性
- **三 文档核查五步法**
  获取文档 → 审阅文档 → 记录发现 → 补充访谈 → 确认签字
- **四 核查要点**
  制度存在、内容完整、审批发布、版本控制、定期评审
- **五 常见问题**
  制度缺失、内容空洞、版本陈旧、未审批、无记录、体系不完整

课后作业与下节课预告

课后作业

必做 完成《安全管理文档核查表》和《汇总表》填写，提交学习通

必做 完成项目5.1在线测试（选择题+判断题，共15题）

选做 收集本单位网络安全制度文件，分析其完整性与合规性

预习 预习活动5.2“模拟人员访谈”，准备访谈提纲

活动5.2：模拟人员访谈

- 安全管理测评之人员访谈技巧
- 证据采集方法
- 访谈记录撰写

课前准备

- 复习GB/T 22239安全管理章节
- 阅读访谈提纲模板

感谢观看

